

信息安全防御体系

安全不是一件产品，它是一个系统工程

课程目标

- 掌握信息安全防御的基本理论和方法
- 掌握网络互联与隔离技术
- 掌握主机防御的技术
- 掌握安全监控的技术
- 掌握安全事件分析的技术
- 开展实战型攻防演练

课程主要内容

- 信息安全防御体系
- 网络隔离技术
 - 互联基础、防火墙、VPN、物理隔离
 - 准入控制NAP, packetfence
- 身份认证（EJBCA、单点登录，手机动态口令）
 - 密码学、身份认证、访问控制技术的基础\PKI、动态口令\单点登录、零信任
- 主机安全监控(zabbix)
 - 主机、web服务、数据库服务监控
- 网络管理与安全监测（ossim, suricata）
 - 基于开源系统的安全监控与管理、入侵监测
- 事件分析（ossec, ELK）
 - 日志搜集、日志分析、日志展示（grafana）
 - 安全事件管理defectdojo
- 应用安全（kali, sqlmap, modesecurity）
 - Web应用扫描
 - Web防火墙
 - SQL注入和XSS跨站

参考资料

- 参考教材

- 《ATT&CK框架实践指南》，张福、程度、胡俊著（参考）
- 《网络安全防御实战—蓝军武器库》，纳迪斯·坦纳著，贾玉彬等译（参考）

课程考核

- 期末考核方式：大作业
- 最终成绩：平时40%+大作业60%
 - 平时成绩：课堂表现20%+平时作业20%

大作业形式

- 角色分配
 - 应急演练方案制定者+麻烦制造
 - 安全事件监控者
 - 性能监控
 - 日志监控
 - 安全防护（抑制、根除、恢复）
 - 参考链接 “https://mp.weixin.qq.com/s/VXTpjOpt1a4l9A4F_Jl9Ew”

提示

- 麻烦制造者：学习ATT&CK框架
 - HexStrike AI、strix、pentagi、CAI
- 性能监控者：
 - Zabbix或Prometheu:
<https://prometheus.io/download/>
- 日志监控者：
 - Wazuh或ELK-SIEM
 - 安全事件闭环管理系统defectdojo

作业综合性要求

- 1、开源系统通常需要完成源码编译
- 2、要在实际场景中测试验证
- 3、系统评估类的作业，应完成远程评估的验证
- 4、作业标题：学号+姓名+系统名（或任务名）



护网行动“攻”与“防”

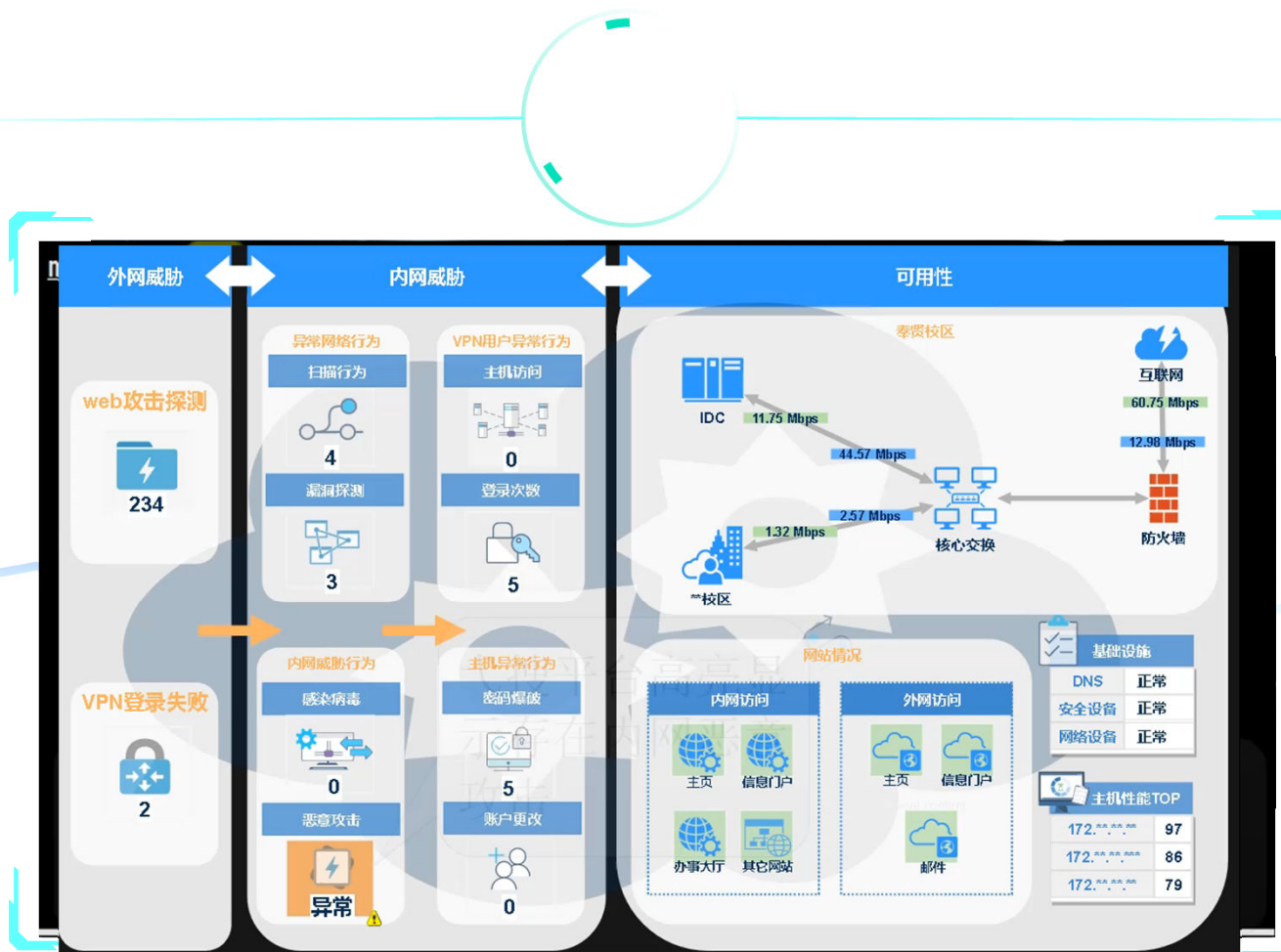
攻

防

1: 爆破VPN用户密码

2: 探测内网存活主机
探测可利用漏洞

3: 漏洞利用



1: 发现VPN登录失败事件异常

2: 发现扫描和漏洞探测行为

3: 发现漏洞利用行为

小练习

- 课前练习:
- <https://pan.sjtu.edu.cn/web/share/5c8705be1b6b188b538978afe68ef09c>, 提取码: f5gg
- 邮件地址: rsshanshan@sjtu.edu.cn

第一课主要内容

- 信息世界的演变与安全
- 信息安全的几个基本问题
- 信息安全防御概述
- 信息安全防御对象

背景：这个世界发生了什么？

- 在商业方面
 - 业务环境更加复杂多变——业务重组、外包、扁平化组织和分布式处理等等
 - 企业与企业的竞争已经演变为数据的竞争
- 数字工业经济
 - 所有公司的预算就是IT的预算，所有的公司都是IT公司。每个企业领袖无一不是数字主义先锋，每个员工都是数字武装起来的员工，我们正在大踏步的迈入数字工业经济时代！
- 信息和信息技术对于很多组织意味着最重要的资产，这导致IT本身已经或潜在成为一个巨大的威胁。

电能的服务演变

- 20世纪早期，有一些之前的几十年里无法想象的事情陆续发生：制造厂商开始关闭、拆除水轮设备、蒸汽机和发电机。要知道，从工业时代开始，电力就是任何产业得以运作的必要前提，工厂作坊除了维持独立发电站来使运作机器以外别无选择。新世纪的到来带来了一种新的可能，许多新兴发电商开始通过建立中央电厂和使用电网给远距离外的客户输送电能。制造商本身不需要再维持独立发电站的运营，他们可以从这些新兴发电商那里购买需要的用电。
- 21世纪的今天发生了什么？

响应信息化的大变革...

- 从以设备/应用程序为中心的世界，转向以信息为中心的世界
 - ✓ 个人的数字化信息正在界定每个人的一切并成为其基本资产
 - ✓ 人们不想让此信息束缚于特定的设备和应用程序中
 - ✓ 设备/应用程序只是来去匆匆的过客，而信息以及人们在信息中的投资则是必须要长期保留的资产
- GUI PC已经出现了各种各样的问题
 - ✓ 人们再也跟不上自己要处理的信息的增长步伐
 - ✓ 说到人们的个人信息，搜索也往往不甚奏效
- 用户越来越看好信息服务数据管理的价值，而不是拥有设备和软件的价值
- 设备快速过期也会成为终端用户上云的重要动因



从IT->DT->AI

IT->DT

- ✓ 未来的核心资源是数据
- ✓ 大数据+机器学习将给这个世界带来无数的冲击
- ✓ 未来一切都将记录，被分析，每一次享受到的贴心的产品改动和服务的升级，无不浸透着无数的数据汇集与精细的分析和反馈。

DT->AI

- ✓ 业务信息化 → 业务智能化
- ✓ 监管信息化 → 监管智能化

注：任何业务over IT → 任何业务over智能化

AI时代

1. **数据驱动：**在AI时代，数据被视为新的石油，是驱动AI发展的核心要素。海量数据的收集、处理、分析和应用成为常态，为AI模型的训练和优化提供了坚实的基础。

2. 信息安全的重要特征： 3. 言出法随

4. **跨界融合：**AI技术正以前所未有的速度渗透到各行各业，与传统产业深度融合，催生出新的业态和模式。无论是制造业、农业、医疗、教育还是娱乐等领域。

信息的重要性

- 对于商业机构或政府机构
 - ✓ 信息已经变成了一个如同建筑物，设备和人力资源一样重要的资产。
- 对于个人
 - 财富的创造与流失、职业的保障与终结、健康的增强或损害，这些都是由于一个因素——信息。

个人与企业应保护什么信息

个人

如生辰八字、
家庭、办公地
网名及密码
出生证明
身份证号、社
电话费清单
大学成绩单

。 。 。 。

企业

企业商业秘密

代码



口令猜测的利器 ——字典生成器

N. C. P. H社会工程学字典

这是一个利用社会工程学原理生成的密码字典，是我在入侵过程中通过对方的密码总结出来的算法，对于破解邮箱、网站和ftp密码比较有用。希望仅作参考测试勿用于非法。
(注:下面的信息为目标人的信息，将根据填入的信息生成字典,收集填入得越多，密码成功的机率越大!)

用户名(拼音):		用户出生日期:		用户邮箱名:	
		示例: 19841010			
用户手机号:		用户座机号:		用户网名(英文/拼音):	
用户名(五笔):		用户邮编:		用户QQ号:	
用户网址:		用户网站成立日期:		所属组织名(拼音):	
常用密码:		习惯用的字符/英文/数字:		女友/妻子名字(拼音):	
女友/妻子电话:		女友/妻子出生日期:		女友/妻子名字(五笔):	
女友/妻子网名:		用户最好的朋友名(拼音):		用户常用注册名(拼音):	

在未填上述信息情况下仍能生成一常规字典

生成密码字典

by rose of <http://www.ncph.net>

口令破解

已知目标系统有一个管理员的帐号为lijun，而且获取了包含管理员个人信息的图片（下图），请利用社会工程学的字典生成器及windows系统的for命令，试探出管理员的口令。



[返回首页](#)

真实姓名：	李军
网名：	Issac
网络年龄：	31
MSN：	issac11017@msn.com
EMAIL：	lj19801017@gmail.com
QQ：	674787523
TEL：	54749110
个人简介：	海到尽头天做岸、山登绝顶我为峰

[评价此人](#) [去相册](#) [听歌](#)

工作机：111.186.56.152:53389

企业信息化快速发展中面临的安全问题

- 信息化建设超速与安全规范不协调
 - 信息安全建设缺乏规范操作，导致信息安全共享难度递增，留下安全隐患
- IT产品类型繁多和安全管理滞后矛盾
 - 缺乏协同、缺乏共享、难以统一管理
- 漏洞管理
 - 由于系统运行不可间断性及漏洞修补风险不可确定性，即使发现网络系统存在安全漏洞，系统管理员也不敢轻易地安装补丁。
- 网络隔离安全和数据交换性
 - 大多数情况，完全隔离不同业务区域并不现实，网络安全必须既要解决不同网络数据交换需求，又要防止安全事件出现。
- 信息系统用户安全意识差和安全整体提高困难
 - 安全制度或安全流程流于形式
- 安全岗位设置和安全管理策略实施难题
 - 一个管理员既要负责系统的配置，又要负责安全管理，“一肩挑”。一旦该管理员的权限被人控制，就导致安全失控。

企业信息安全的四个阶段

安全制度

3、制度型企业（流程导向阶段Procedure Oriented）：

- ✓ 强调安全管理的重要性；
- ✓ 每年信息安全经费预算有所增加；
- ✓ 开始对信息资产进行分类；
- ✓ 建立了正式的安全组织，拥有完善的安全策略、标准和流程；
- ✓ 部署了基本的安全工具，但是安全制度和流程落实程度不够。

1、被动型企业（事件导向阶段Incident-response Oriented）：

- ✓ 事件、故障发生以后再采取相应的补救措施；
- ✓ 不注重IT的安全管理；
- ✓ 使用基本的用户名、密码管理；
- ✓ 部署了基本的安全工具；
- ✓ 每年信息安全投资预算占整个IT预算的份额非常低。

这个阶段属于信息安全建设的初级阶段/Initial Phase for ISMS，目前大多数中小企业都属于这一阶段。

4、成熟型企业（风险导向阶段Risk-mitigation Oriented）：

- ✓ 强调IT的安全管理和安全技术的平衡；
- ✓ 建立统一的安全体系管理架构、技术架构；
- ✓ 拥有基于国际标准的完善的安全策略、标准和流程；
- ✓ 建立了强健有力的安全系统；
- ✓ 应急响应机制完善且定制演练；ER Plan & Drills
- ✓ 预防为主、防治结合、内外兼修。

2、技术型企业（技术导向阶段Technology Oriented）：

- ✓ 强调并依赖IT的安全技术；
- ✓ 部署了各种领先的安全工具；
- ✓ 每年安全经费预算投入在IT投资中开始被重点考虑，数量有较大增加；
- ✓ 建立了弱安全组织，有一定的安全策略、标准和流程；
- ✓ 员工安全意识普遍比较薄弱。

这一阶段属于大量技术投入阶段/Technology investment。

安全技术

安全问题的根源

管理隐患

- 是否符合相关法律法规的要求?
- 出现安全事件是否有成熟应急预案处置?
- 员工入职是否有安全培训?
- 员工离职是否收回账号等虚拟IT资产?
- 每年网络安全投入预算是否能支撑实际需求?
-

人的隐患

- 员工的电脑登录口令是否复杂?
- 服务器是否限制服务商U盘的插拔?
- 运维人员对服务器的操作是否合规?
- 是否有识别机制判断谁, 在何时, 从何地使用teamviewer等远程工具?
-



技术隐患

- 办公区域是否可以随意访问产线电脑/服务器?
- 员工是否经常抱怨企业邮箱垃圾邮件较多?
- 是否担心生产停机而无法及时打补丁?
- 是否担心开启防火墙导致业务系统服务受到影响?
- 业务系统服务中断, 运维人员无法及时知晓?
-

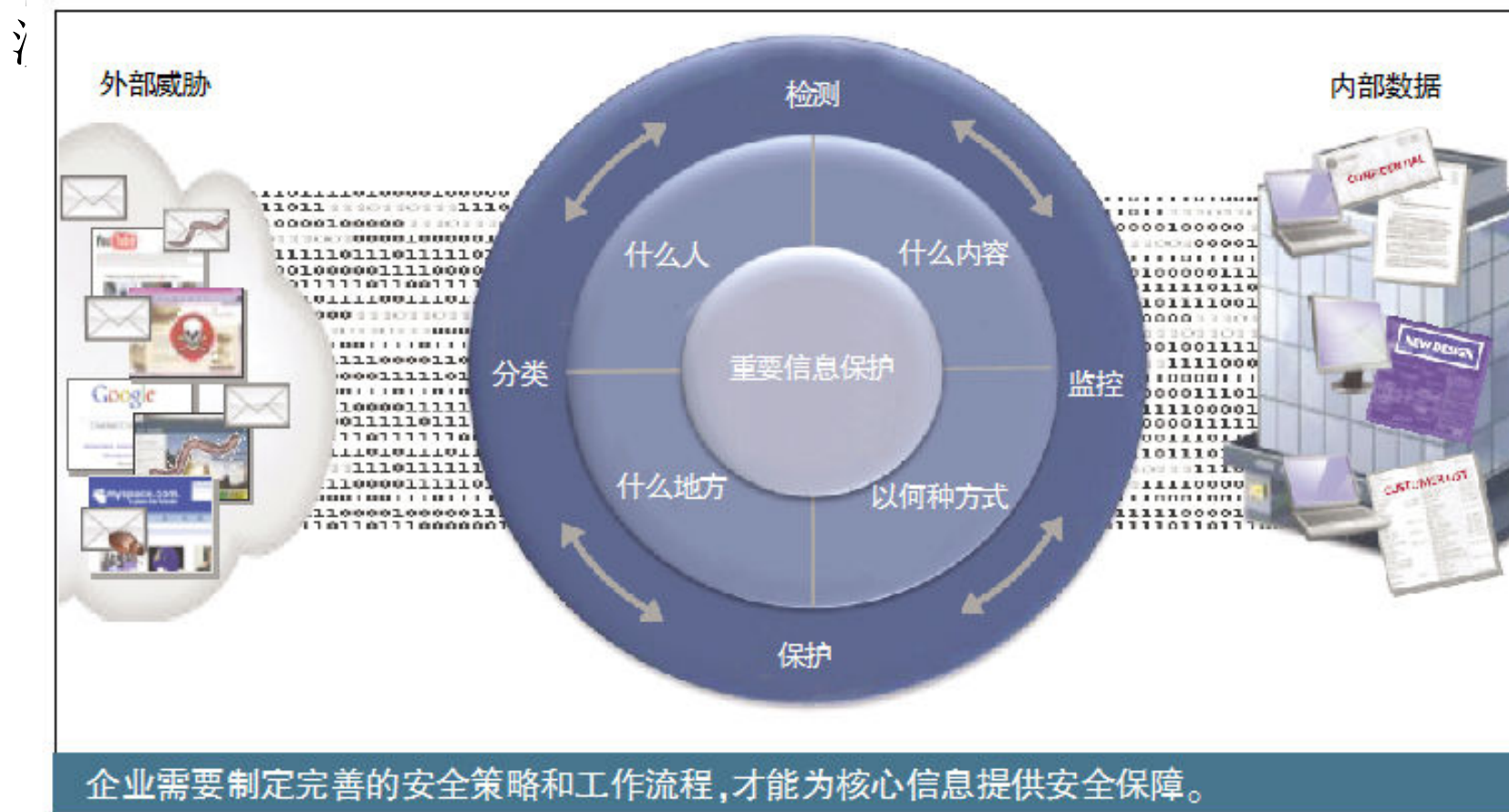
数据隐患

- 是否记录运维人员对数据库进行各类操作?
- 数据是否备份? 能否及时对操作不当导致丢失的数据或勒索病毒加密的数据进行恢复?
- 能否对通过工具外发企业重要数据的行为进行识别并阻断?
-

信息安全：位于管理革命之巅

三分技术，七分管理，十二分数据

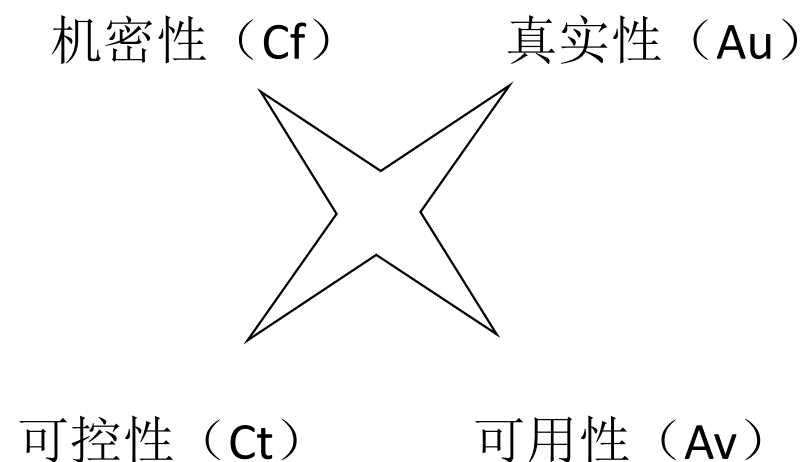
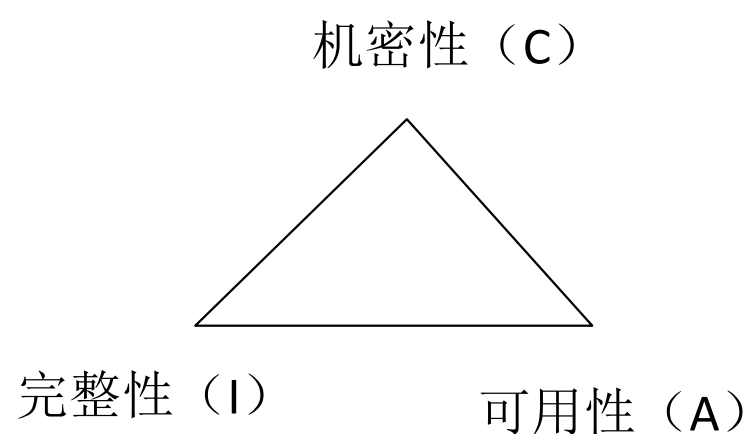
- 当今的信息安全领域正处在变革之中。直到最近，该行业仍然被**控制技术的专家所支配**，他们提供了信息服务，而且行业被局限于计算机和网络操作领域。现在信息安全工作正在快速演化成一种管理原则，它



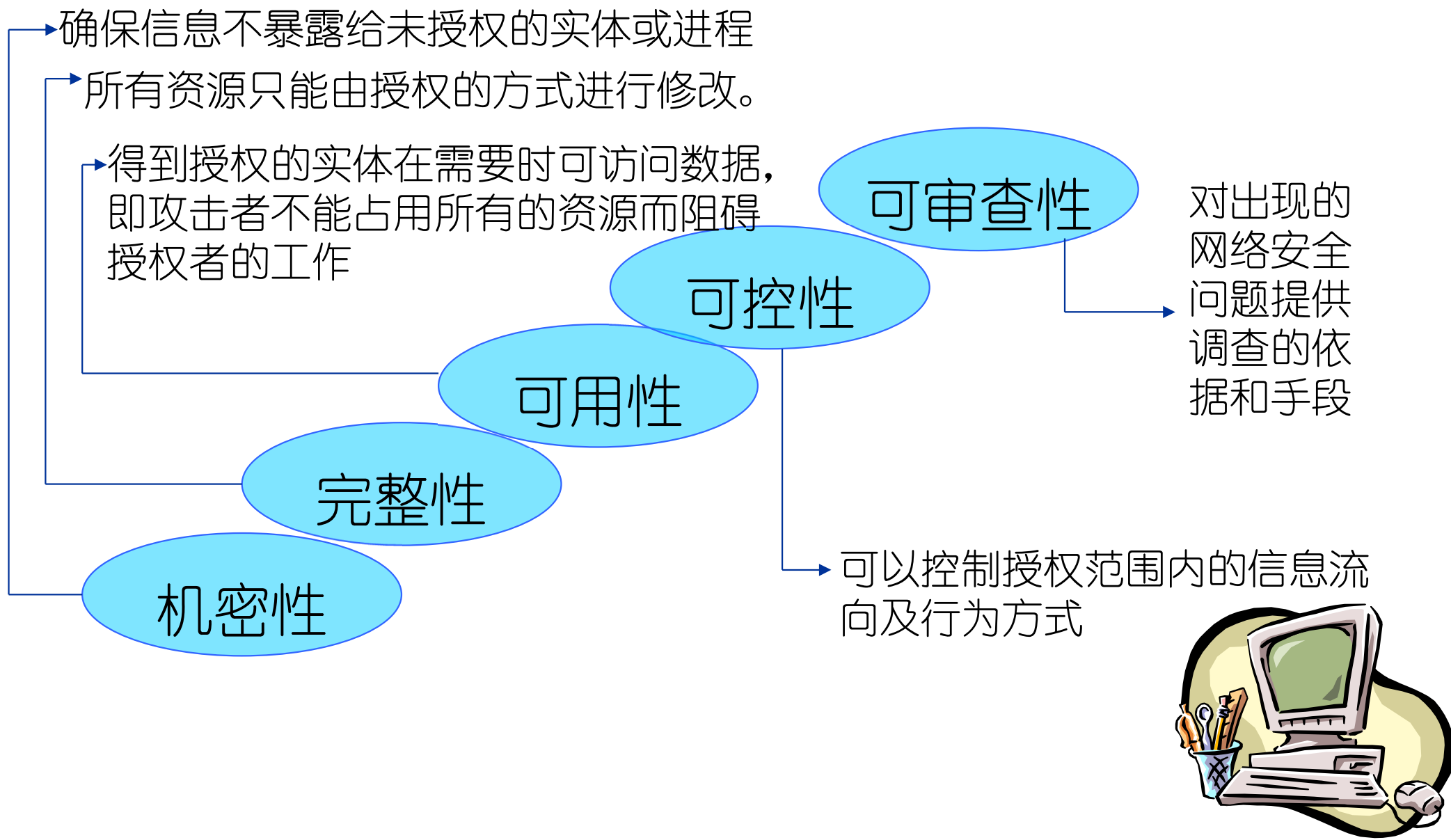
第一课主要内容

- 信息世界的演变与安全
- 信息安全的几个基本问题
- 信息安全防御概述
- 信息安全防御对象

信息安全从三要素到四要素的演变



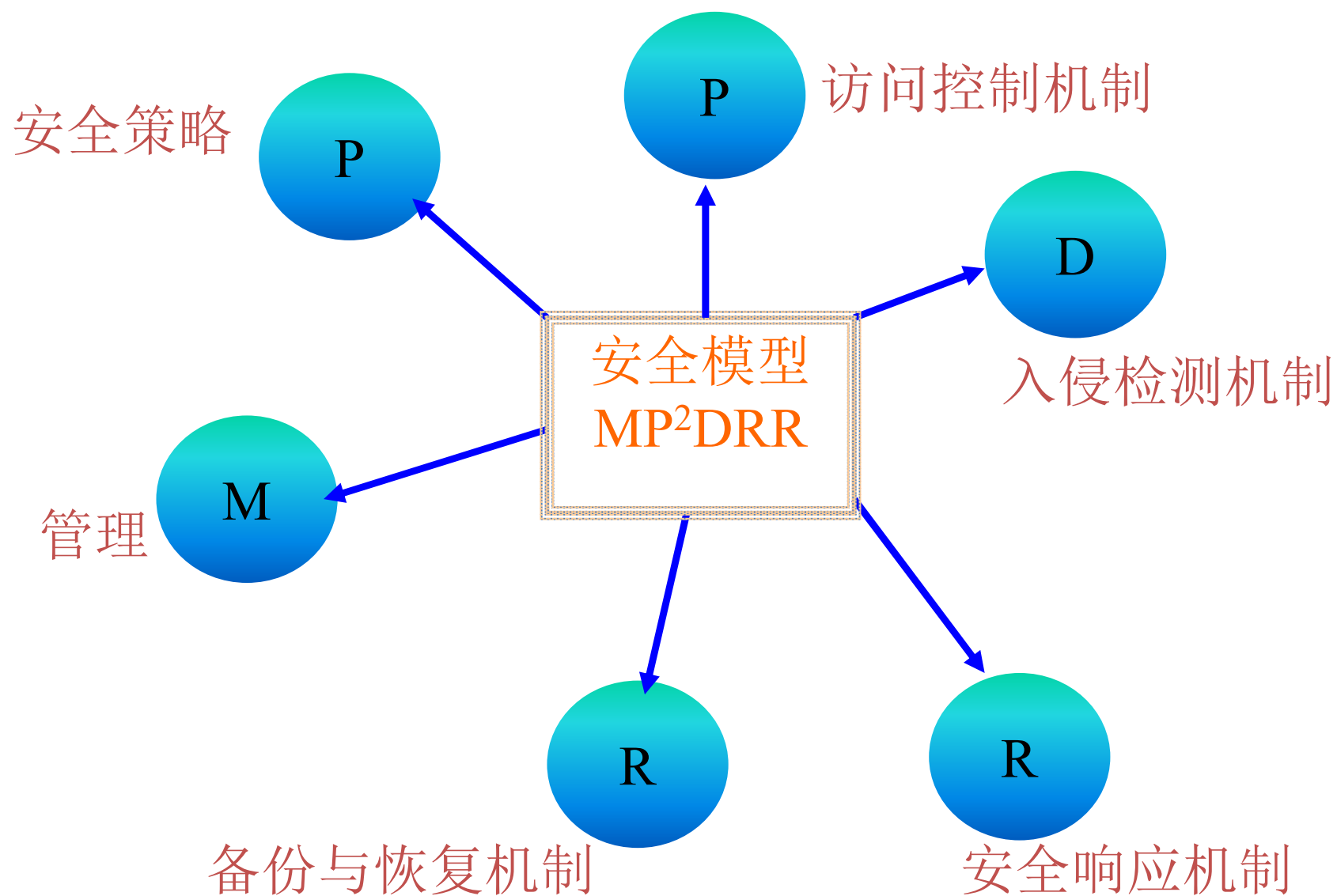
信息安全基本五要素

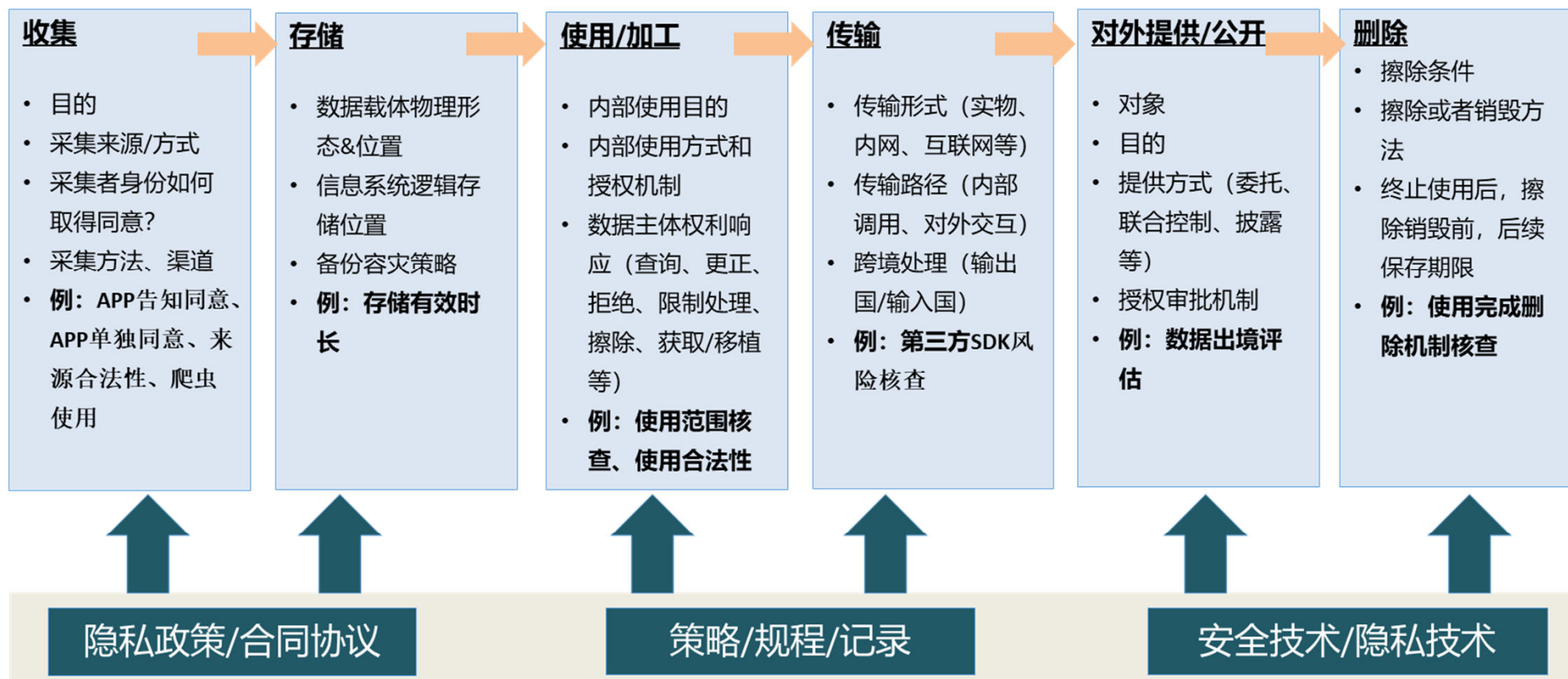


信息安全的安全要素层次架构

层次	层面	作用点	安全属性
信息对抗	信息熵对抗	信息利用	机密性、完整性、特殊性
信息安全	内容安全	攻击信息	机密性、真实性、可控性、可用性、完整性、可靠性
	数据安全	保护信息	机密性、真实性、实用性、完整性、唯一性、不可否认性、生存性
系统安全	运行安全	软件	真实性、可控性、可用性、合法性、唯一性、可追溯性、占有性、生存性、稳定性、可靠性
	物理安全	硬件	机密性、可用性、完整性、生存性、稳定性、可靠性

信息安全动态模型





数据处理全生命周期

第一课主要内容

- 信息世界的演变与安全
- 信息安全的几个基本问题
- 信息安全防御概述
 - 威胁与攻击
 - 防御体系及技术路线
 - 大规模网络安全面临的问题
 - 持续自适应风险与信任评估
- 信息安全防御对象

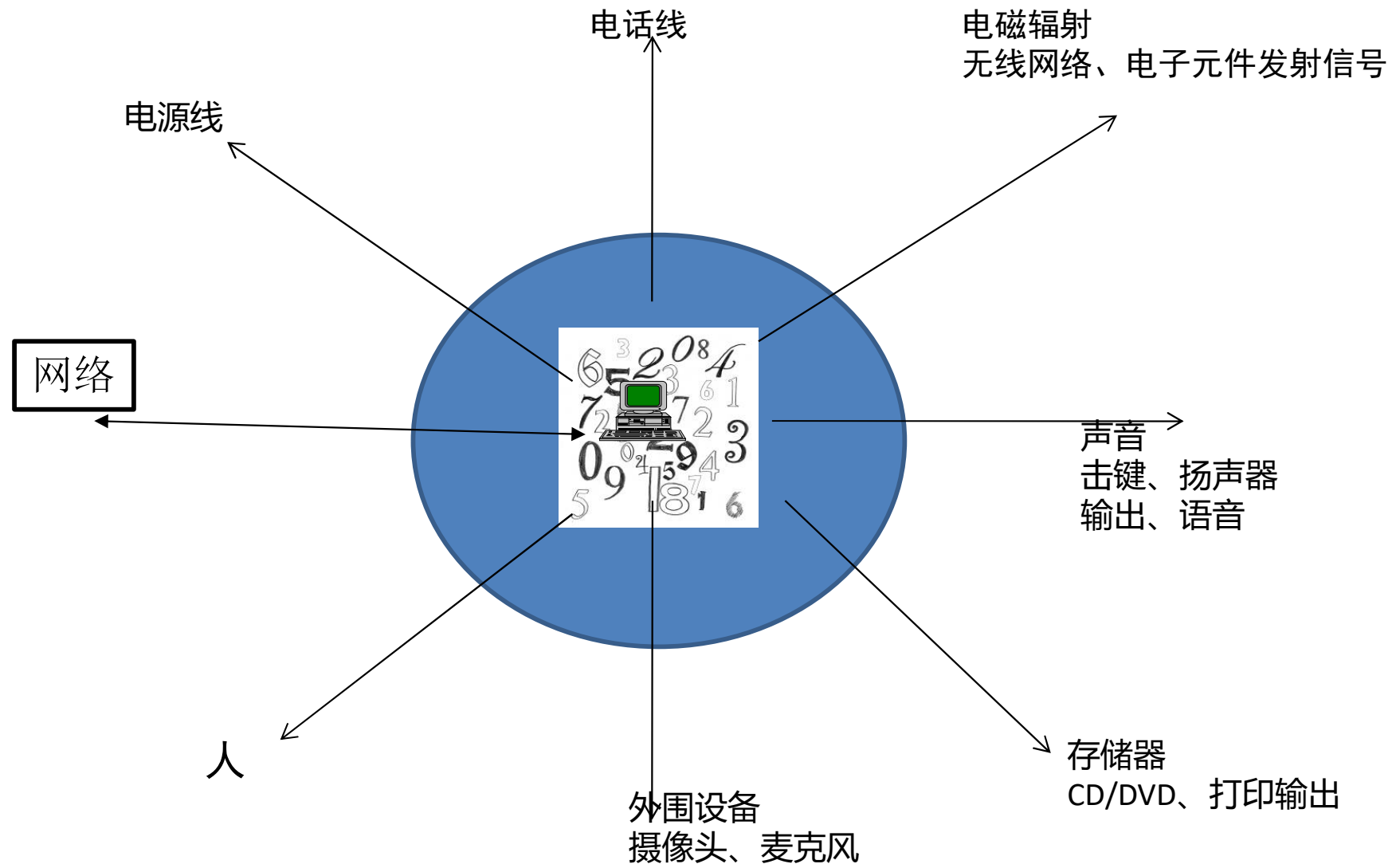
企业中IT系统出现故障有八大原因：

据国外一份统计数据表明,企业中IT系统出现故障有八大原因：

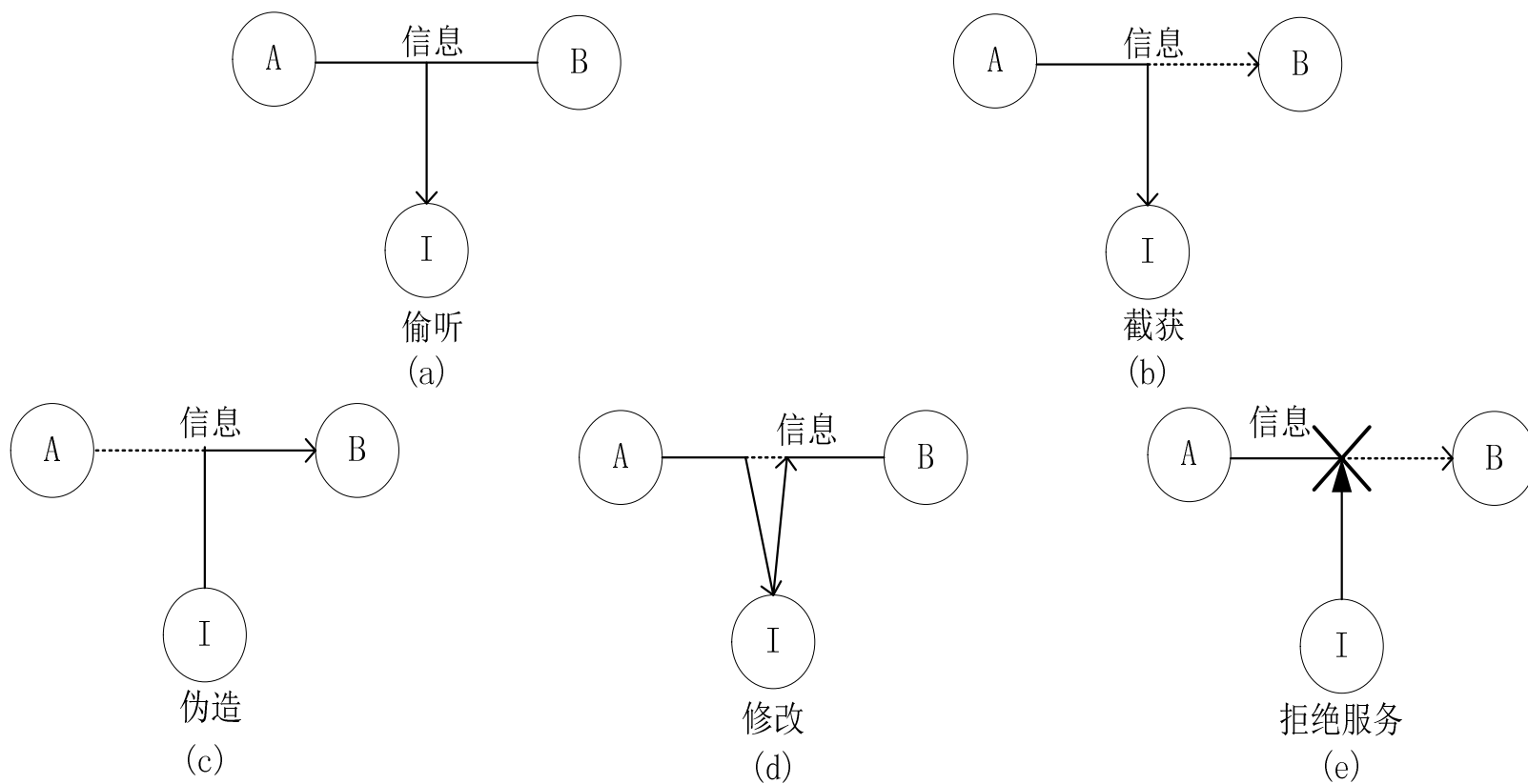
- 1、恶意代码攻击；
- 2、缺乏有效的监控制度和手段；
- 3、IT设备本身的性能问题；
- 4、应用系统/数据本身存在问题；
- 5、员工缺少技能培训；
- 6、不同部门的IT人员之间缺乏协调；
- 7、缺少运营管理方法论的指导；
- 8、员工不按规定/流程操作。

可以看到在这些原因中都和管理与流程存在很大关系，要做好组织中的IT风险控制和信息安全离不开IT治理。

计算机的信息流



网络信息面临的威胁



攻击方式

- 信息搜集
 - 获取口令
 - 扫描
 - 社会工程学
- 信息密取
 - 放置特洛伊木马程序
 - 密码破解
- 系统控制
 - 偷取特权
 - 通过一个节点来攻击其他节点
- 资源耗尽攻击
 - 拒绝服务
 - 电子邮件攻击

攻击技术能力图谱

基础能力

Web漏洞利用

命令执行	SQL注入	代码执行	逻辑漏洞
解析漏洞	信息泄露	XSS	配置错误
弱口令	反序列化	文件上传	权限绕过

基础安全工具利用

Burp Suite	sqlmap	AppScan
	Nmap	Wireshark
MSF	Cobalt Strike	

进阶能力

Web漏洞挖掘

命令执行	SQL注入	代码执行	逻辑漏洞
解析漏洞	信息泄露	XSS	配置错误
弱口令	反序列化	文件上传	权限绕过

Web开发与编

Java	PHP
Python	C/C++
Go	

编写PoC或EXP等利用

Web漏洞
智能硬件/IoT漏洞

社工钓

开源情报搜集	社工库收集
鱼叉邮件	社交钓鱼

高阶能力

系统层漏洞利用与防

SafeSEH	DEP
PIE	NX
ASLR	SEHOP
GS	

系统层漏洞挖掘

代码跟踪	动态调试
Fuzzing技术	补丁对比
程序逆向静态分析	
系统安全机制分析	

身份隐藏

匿名网络
盗取他人ID/账号
使用跳板机
他人身份冒用

内网渗透

工作组、域环境渗透	
横向拓展	
内网权限维持/提权	
数据窃取	免杀

高级安全工

IDA	Ghidra
Binwalk	OllyDbg
Peach Fuzzer	

编写PoC或EXP等高级利用

Android	iOS
Linux	macOS
网络安全设备	

掌握CPU指令

x86	MIPS
ARM	
PowerPC	

团队协作

行动总指挥	情报搜集人
武器装备制造人	打点实施人员
社工钓鱼人员	内网渗透人员

纵深防御体系架构

- 网络中单薄的孤立防线较容易被攻击者突破，防御能力有限。若把多道防线有机结合起来，在纵深范围内构筑成统一的防御体系，那么攻击者突破了个别的防线后，还会遇到更多防线，要想达到攻击实效就会困难得多。
- 典型模型PDRR，防护/检测/响应/恢复

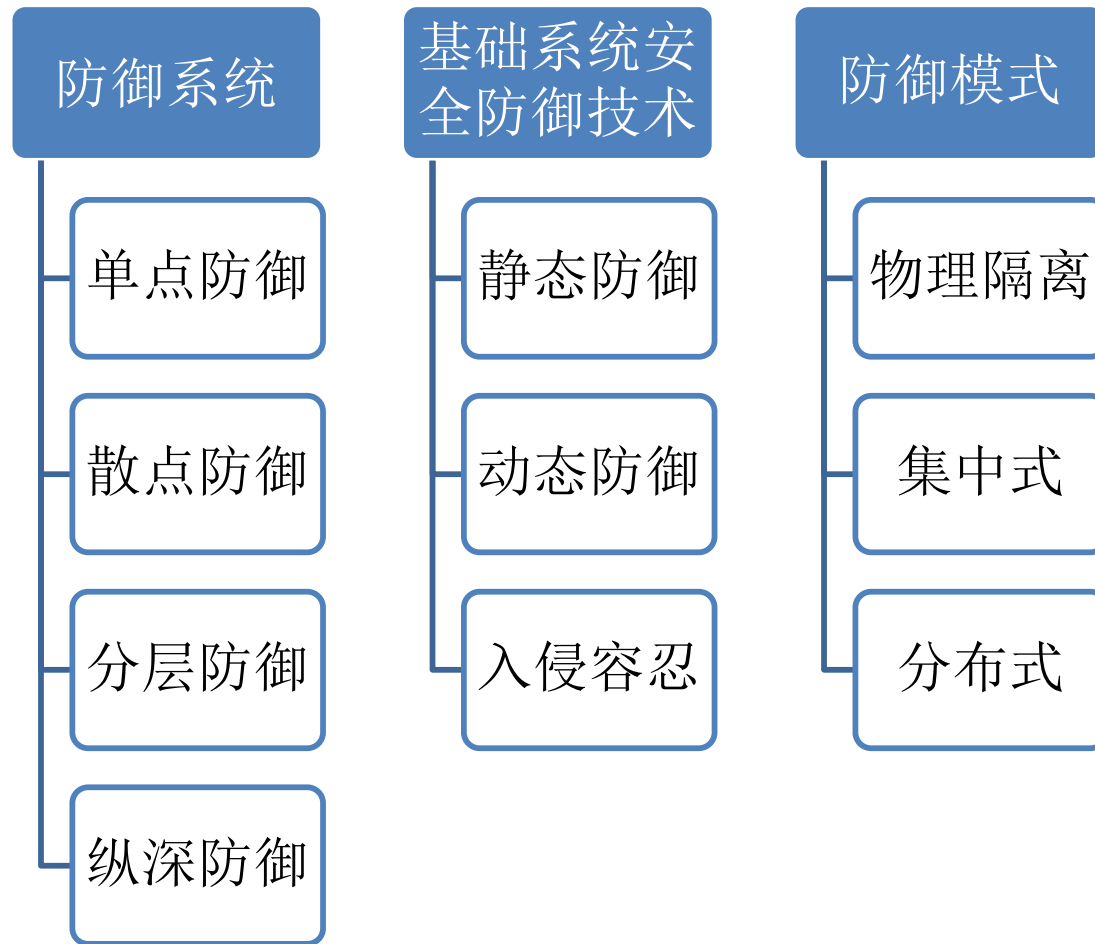
信息安全防御体系演变



网络安全防御技术的路线

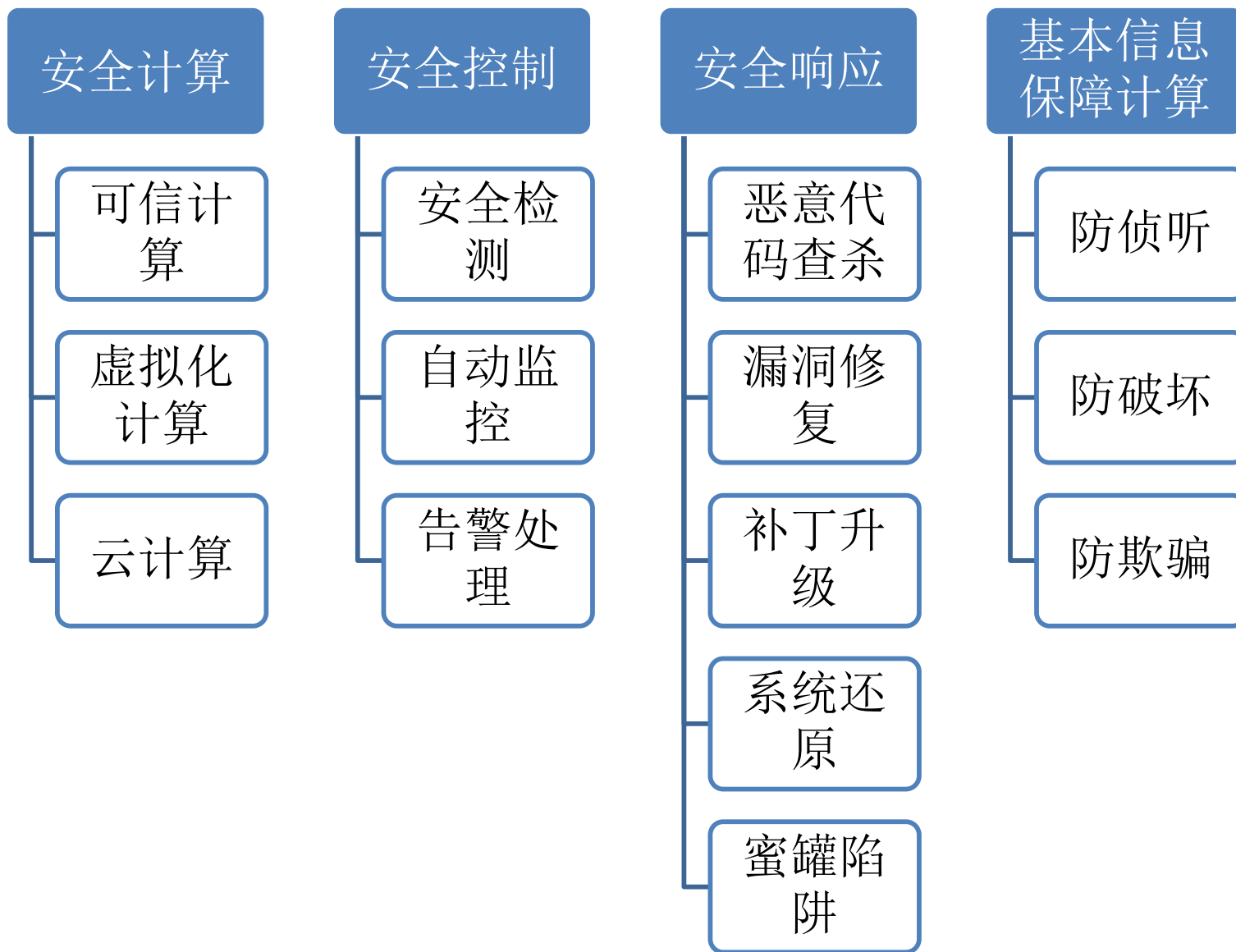
- 安全防御体系架构及其机制
- 底层系统安全防御各种细节
- 高层应用安全防御

安全防御体系架构

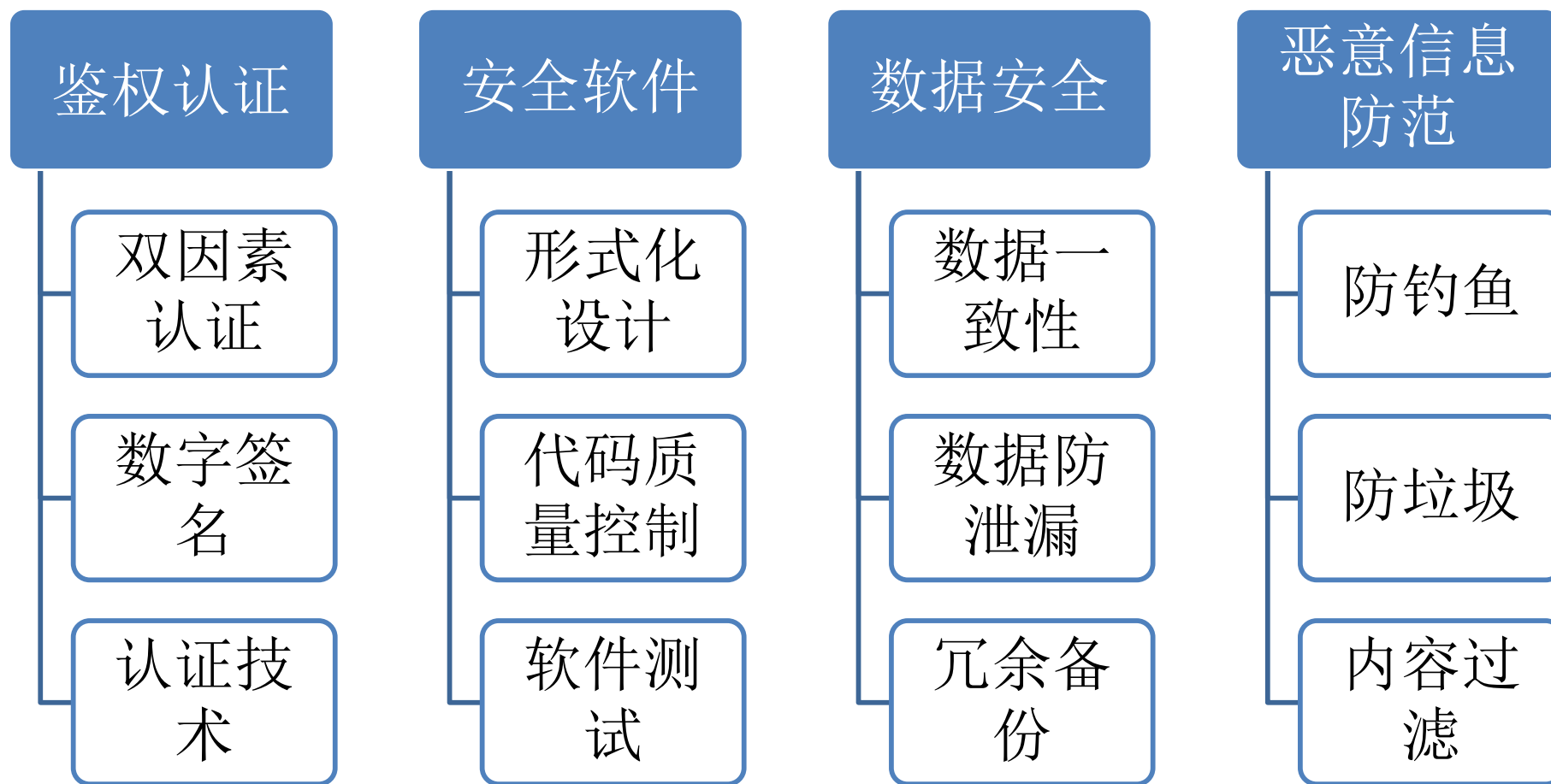


重大演变之一：保护和隔离——》检测和防御——》可生存性的保护机制

基础防御技术



应用防御技术



重大演变之二：亡羊补牢——《代码自动审查——》软件的形式化构造：构建安全代码

大规模网络安全面临的新问题



网络应用数量和规模的急剧增长

网络应用服务各节点可能存在的安全攻击的差异性日趋鲜明

应用网络结构的动态复杂性急剧增加

网络安全攻击拓扑结构的复杂度急剧增加

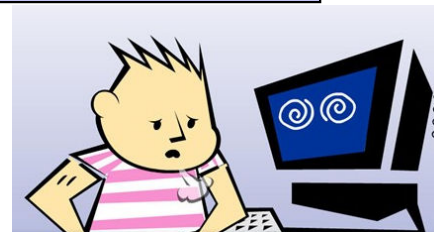
大规模分布式攻击

多阶段协作式攻击

迂回式攻击。。。

攻击越来越复杂，攻击能力越来越强，攻击造成的损失和破坏越来越大

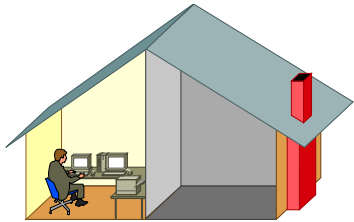
**现有的安全防御系统
功能失效**



大规模网络安全管理的现状



攻击与防护成本的不对称，



黑客技术与工具的传播造成攻击者门槛的逐渐降低



新技术的不断应用，造成攻击途径的多样化



现有的安全防御系统在主动防护、主动预警、决策响应等方面存在无法解决的问题



现有的安全防御系统功能失效



大规模网络对安全管理的需求



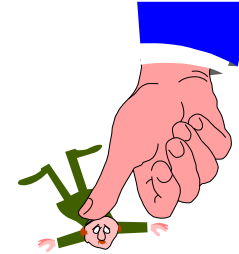
安全产品
与措施分
散



安全事件消
极被动地响
应



响应措施智
能化程度不
高



主动预警、
主动防御效
果不好



**针对大规模网络实施有效的安全
管理与监控**

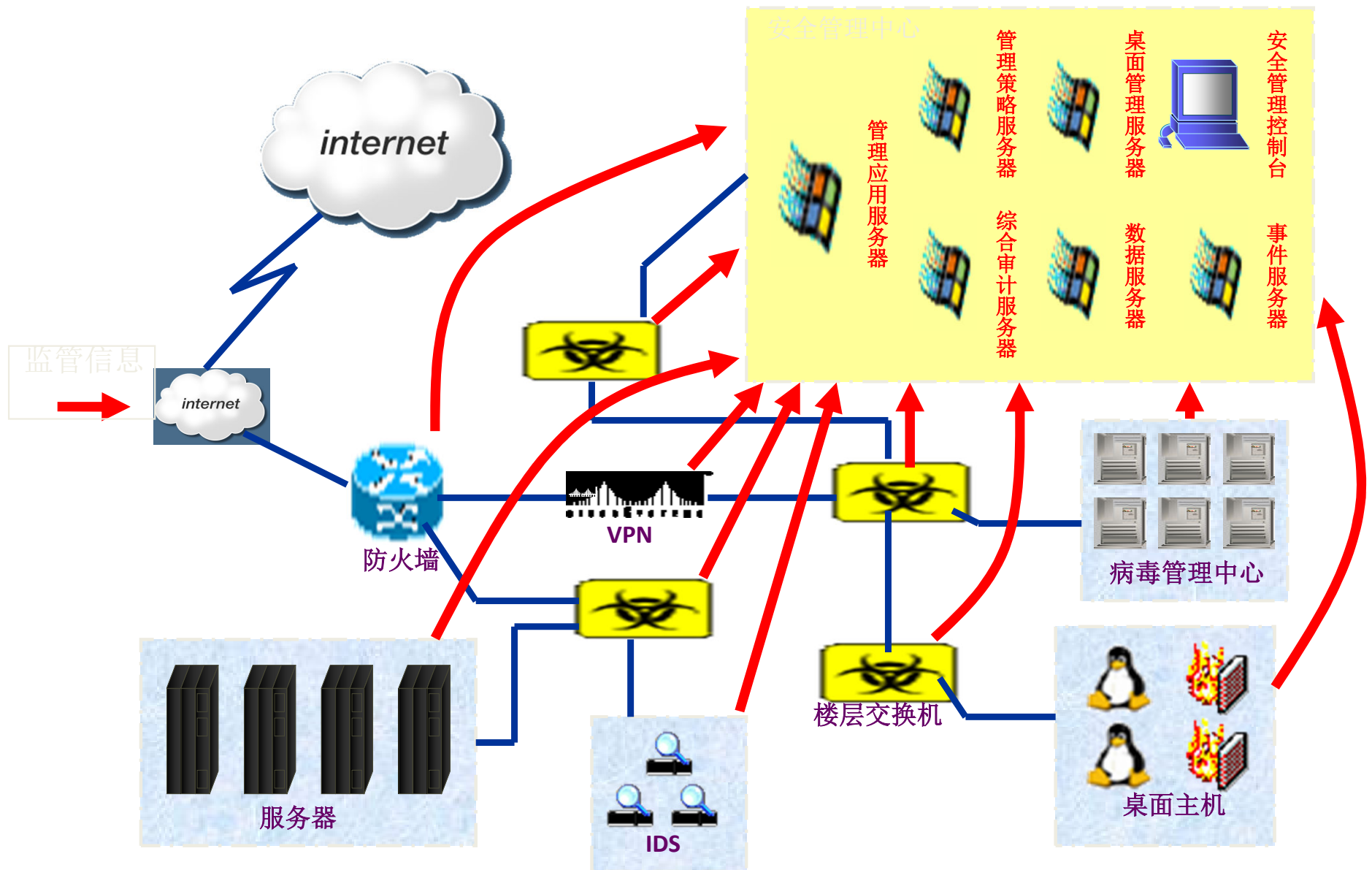
大规模网络对信息安全的技术需求

- 军队、国防、政府等和国家安全相关的几种大规模网络的实际需求可以发现，尽管各种网络的功能和面临的挑战存在差异，但是在对信息安全的需求方面体现出了整体的高度相似性。
- 各种网络对信息安全的需求都包含了风险评估、实时安全事件处理以及应急安全响应三个部分。
- 安全设备的堆积形成越来越多的安全日志，海量的日志无法通过人工分析得到有价值的信息。必须通过智能分析手段加以提炼，同时辅以有针对性的专业技术分析。

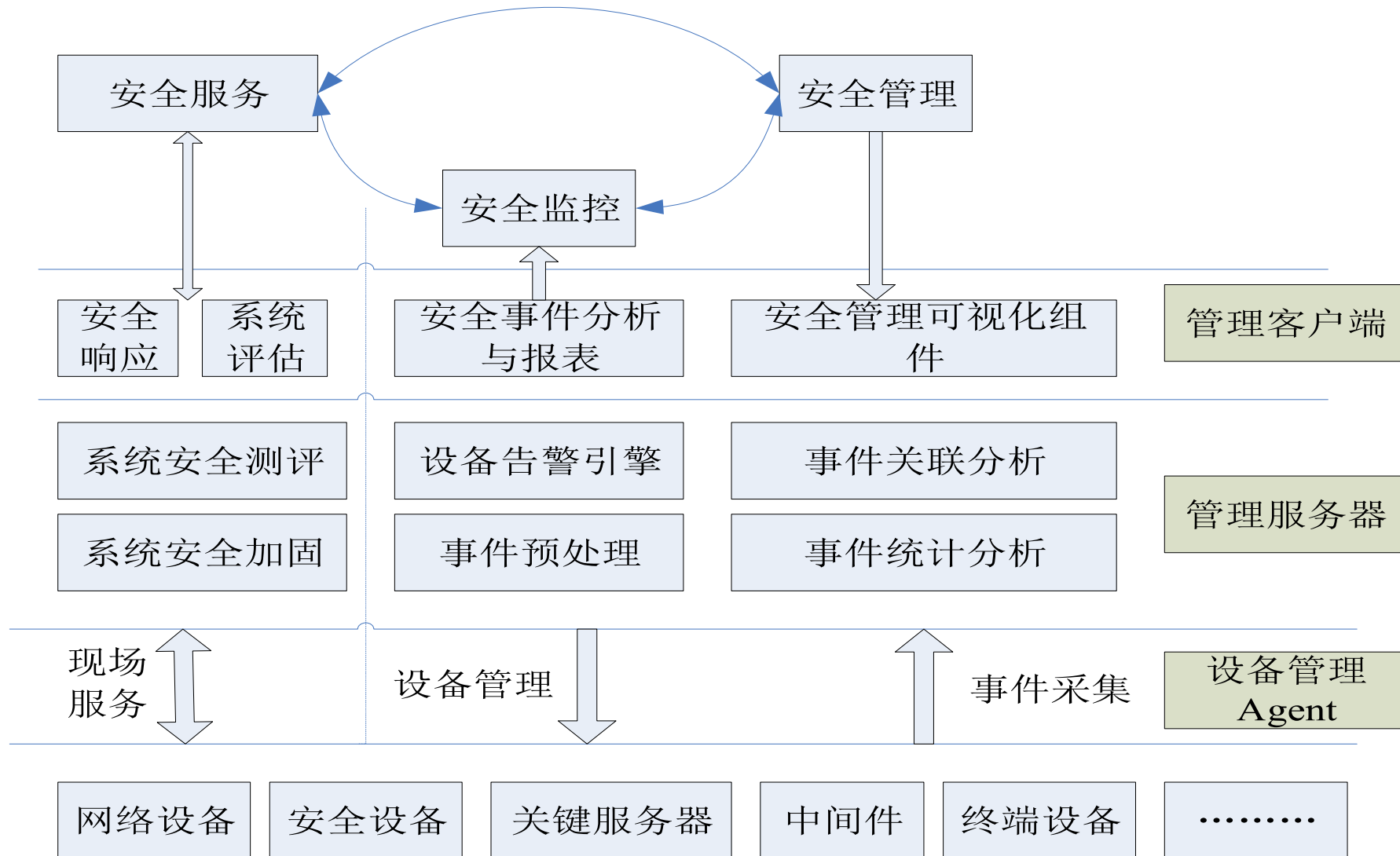
大规模网络带来的问题与解决思路

- 复杂性 → 管理困难
 - 风险评估：围绕关键指标，降低复杂度
- 异构性 → 难以理解
 - 事件关联分析：寻找内在联系，把握整体态势
- 大规模 → 维护困难
 - 智能决策：提高自动化程度
- 重要性 → 损失代价高
 - 海量实时处理：提高及时性；成本控制

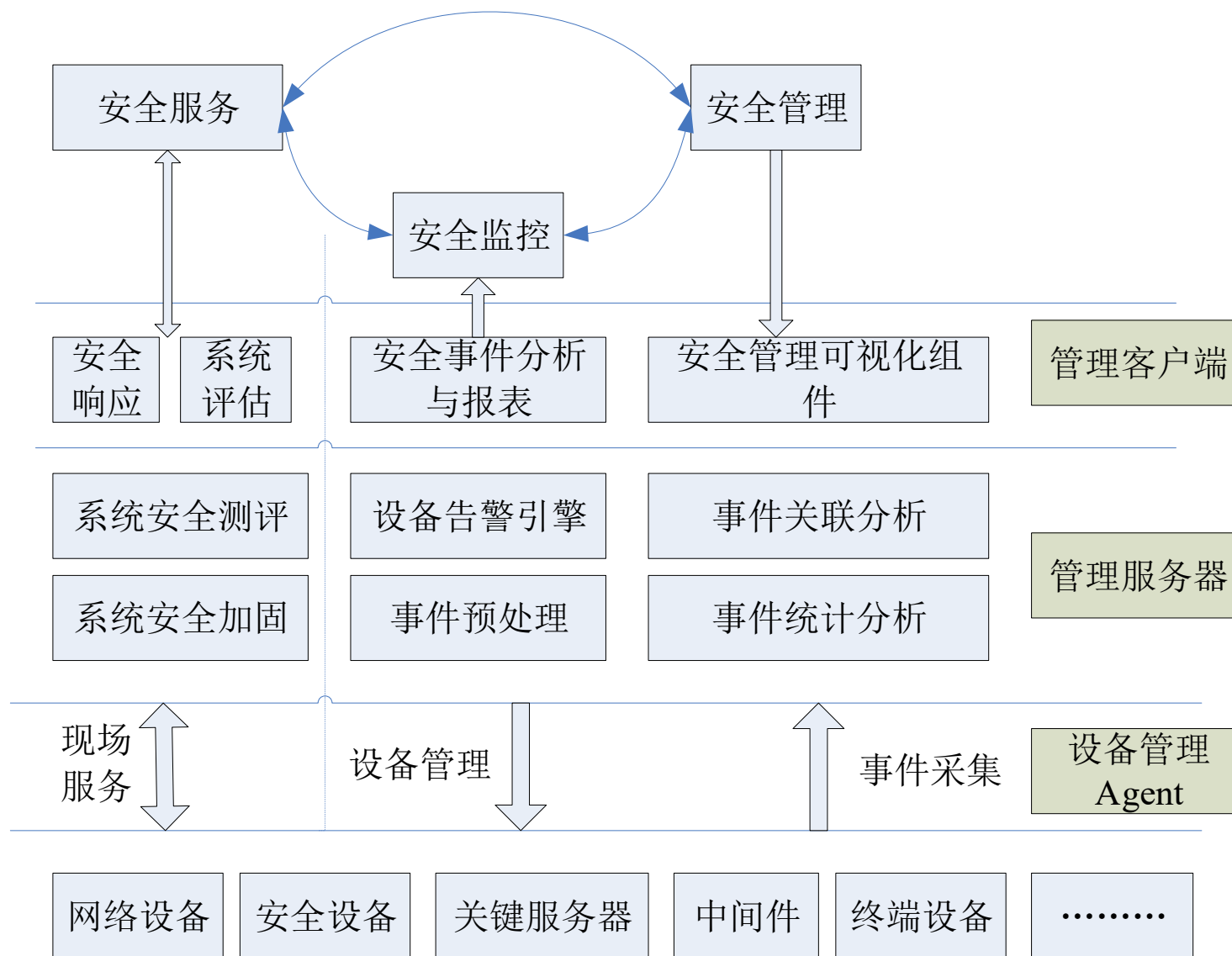
大规模网络安全管理要素提取与建模



大规模网络主动防御逻辑框架

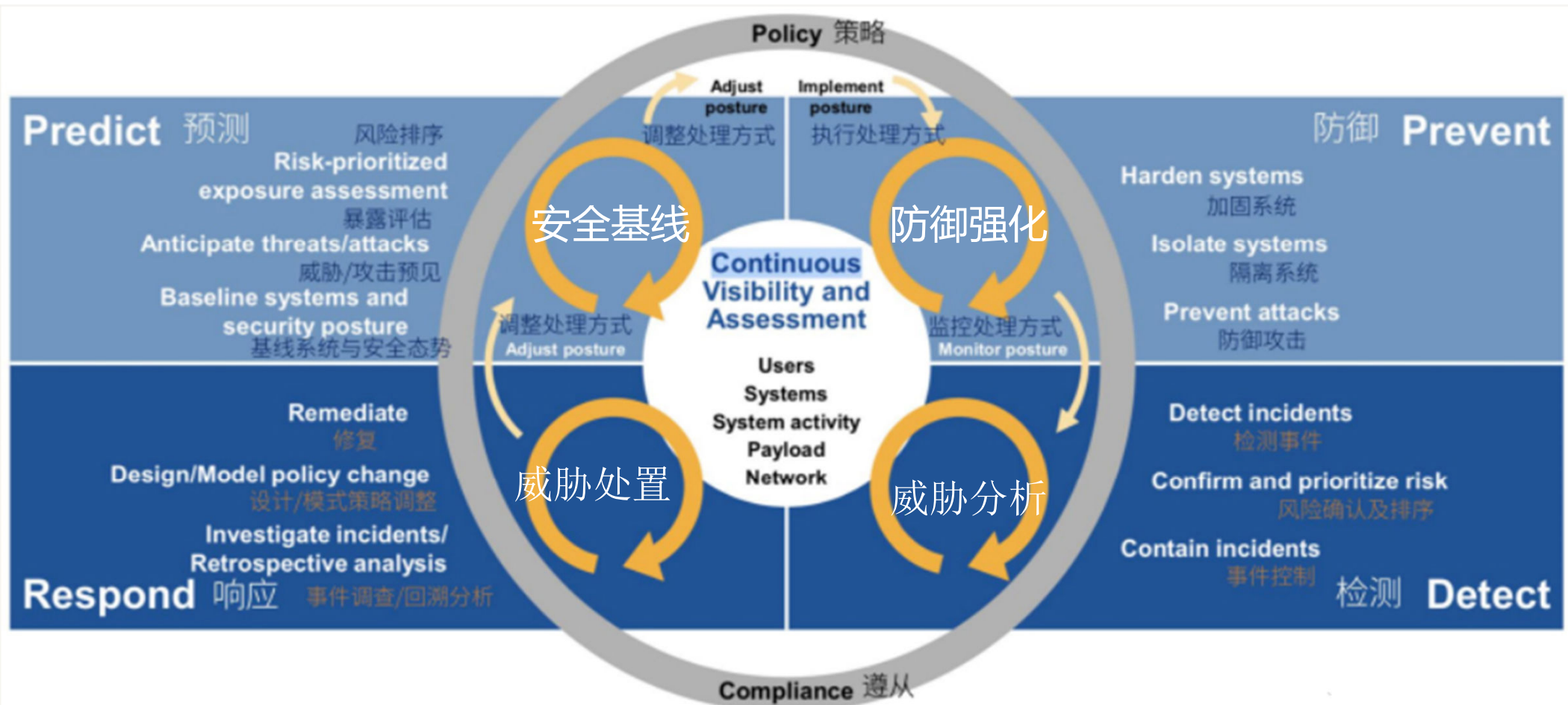


网络安全管理、监控与服务的工程应用



主动防御与持续响应的自适应安全架构

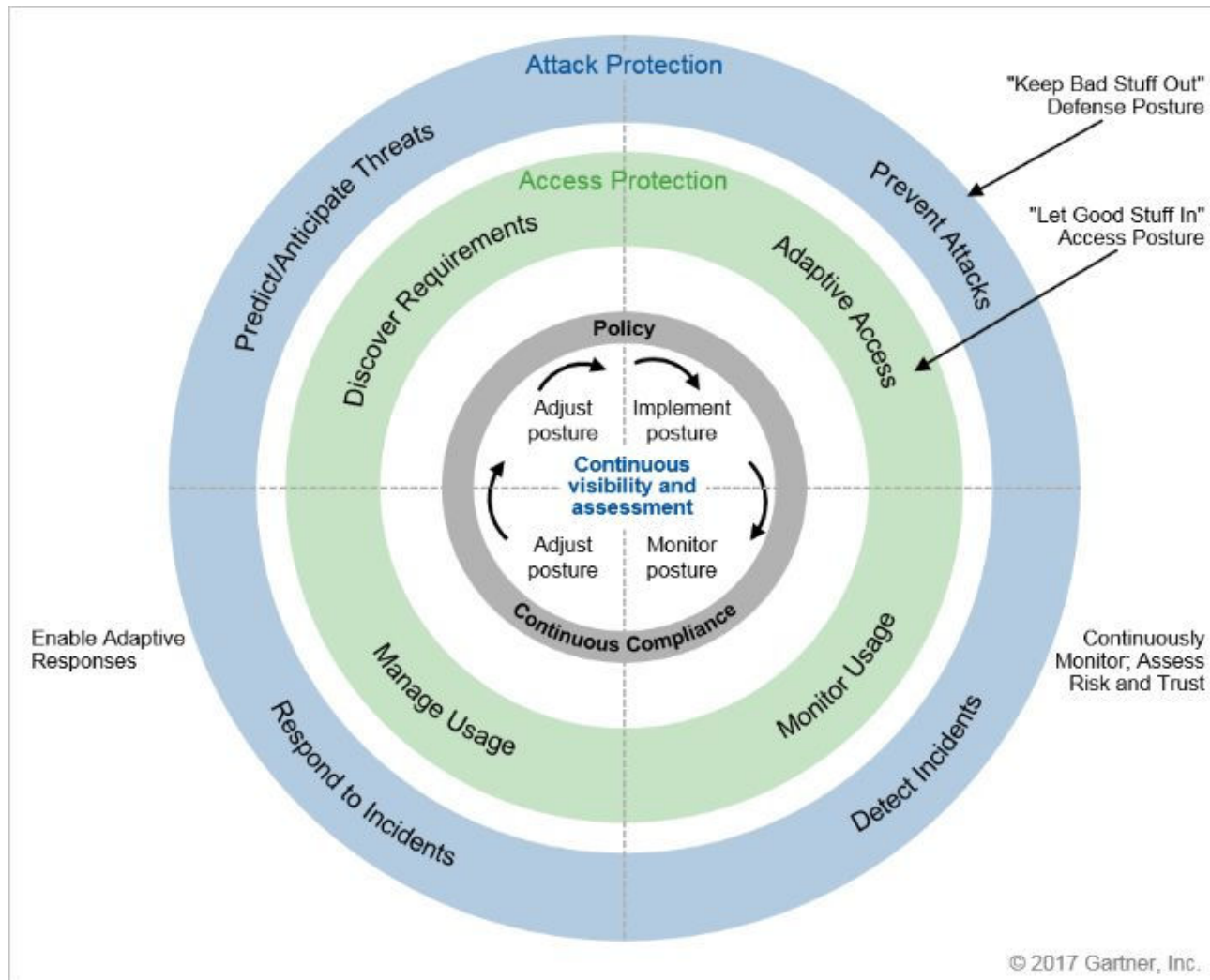
Adaptive Security Architecture, ASA



2017年，自适应安全架构2.0的主要变化包括：加入了用户和实体行为分析模块（User and Entity Behavior Analytics, UEBA）；在四个模块间的大循环闭环体系不变的同时，在各自的模块中引入小的循环体系以表示每个模块所承担的角色功能；在大循环中加入了策略与合规的要求，进一步提升了自适应安全架构的普适性。

持续自适应风险与信任评估

(Continuous Adaptive Risk and Trust Assessment, CARTA)



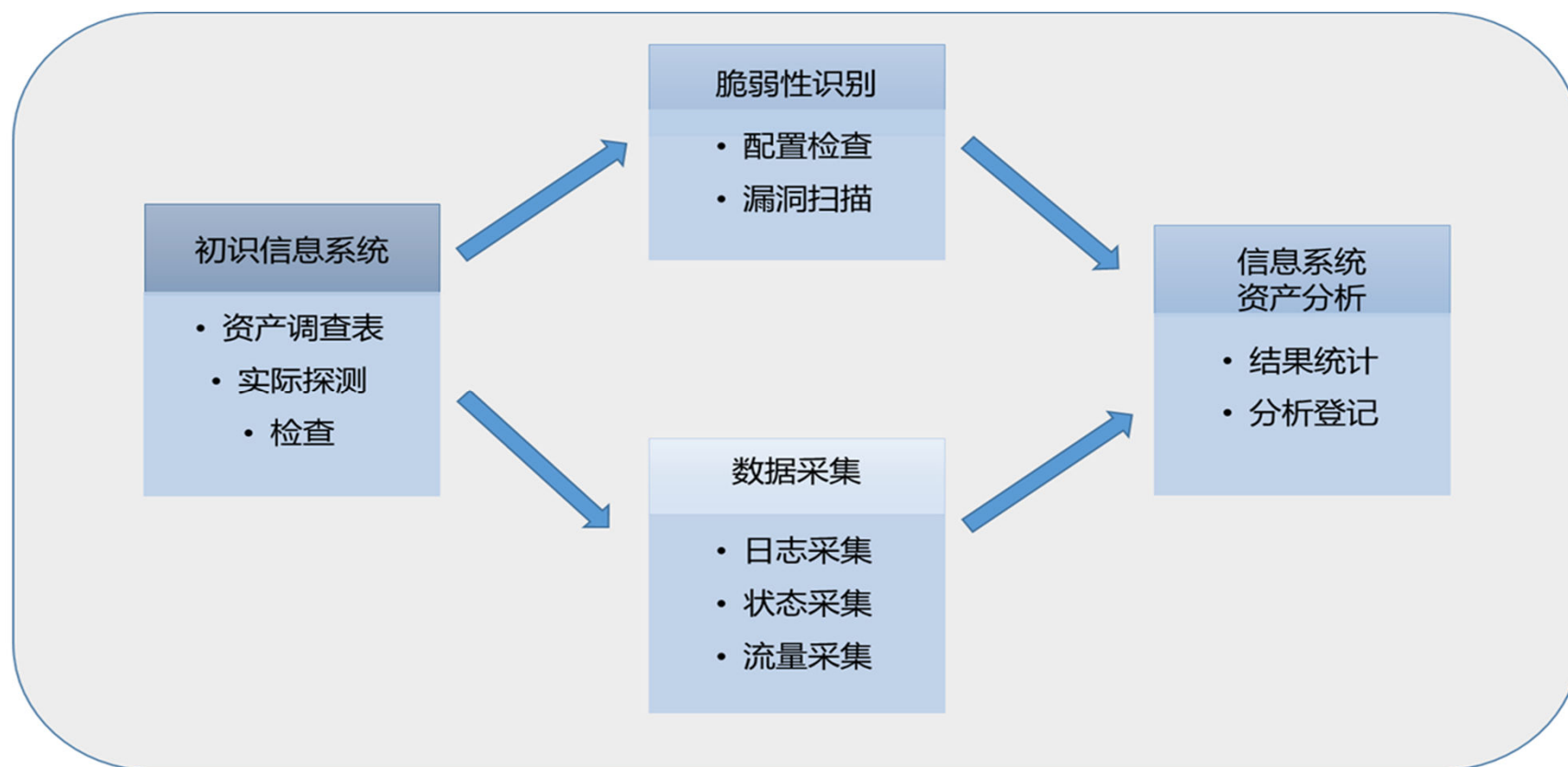
2018年，CARTA体系中新增了关于访问的保护内环，将2.0的架构作为攻击的保护外环，同时还将云访问安全代理（Cloud Access Security Broker, CASB）迁移到了总体架构中。自适应安全架构3.0无论是自适应的认证鉴权体系还是安全防御体系均形成了闭环

第一课主要内容

- 信息世界的演变与安全
- 信息安全的几个基本问题
- 信息安全防御概述
- 信息安全评估对象
 - 信息资产
 - 信息系统分类
 - 信息系统属性
 - 信息系统属性识别

信息资产概述

信息资产由计算机及其相关的和配套的设备、设施(含网络)构成的，按照一定的应用目标和规则对信息进行采集、加工、存储、传输、检索等处理的人机系统。典型的信息系统由三部分组成：硬件系统（计算机硬件系统和网络硬件系统）；系统软件（计算机系统软件和网络系统软件）；应用软件（包括由其处理、存储的信息）。



信息系统分类

- IT基础设施
 - 基础网络服务：基础网络服务包括DNS、DHCP、NTP、数据库等服务
 - 网络系统：网络环境包含网络拓扑、路由器、交换机等网络设备
 - 虚拟化平台：共享包括计算、存储、网络资源
- 网络边界系统及安全防御系统
 - 防火墙类：各级防火墙WAF、IPS、数据库防火墙、主机防火墙；
 - 路由器和三层交换机（核心层和汇聚层）也可能成为边界设备；
 - VPN
 - 通信代理的边界：包括代理服务器、NAT设备、远程桌面、SSH等；
- 业务系统：
 - 与信息处理相关的作用，如信息收集、信息加工处理、信息存储、信息利用等；
 - 提供了支持决策、管理、计划、执行、反馈与控制等管理功能。

信息系统的属性

- 信息系统的客观存在是结构属性、交互属性、反应属性三位一体的统一。
 - 结构属性：体现稳定性维度
 - 交互属性：体现关系性维度
 - 反应属性：体现变化性维度

结构属性

- 信息系统具有自身的特征和规律，具有密切联系的统一整体的特性，是其在网络空间存在的基础特征，代表信息系统的稳定性维度，用于标识实体，主要包括如下特征
 - 基础特征
 - 自有特征
 - 脆弱特征

结构属性-基础特征

- 基础特征表明了信息系统对网络空间的IT基础设施的依赖关系，是IT基础设施的一组指标，主要包括常见网络应用、网络互连环境、虚拟化系统的标识特征。例如网关IP、DNS|DHCP|NTP服务器的IP地址/MAC地址、数据库服务器的IP地址/MAC、路由表、VLAN、虚拟资源池等信息。

结构属性-自有特征

- 描述信息系统内部各组件的标识及相互之间的组织关系的一系列指标，用于区别网络空间其他系统，主要包括如下特征。
 - 资产管理信息：通过访谈和核查工具可以明确传统的信息系统的“台帐”信息，如各组件资产的名称、编号、类别、规格型号、使用主体、供应商等资产管理信息。
 - 网络空间的专属标识信息及内部关联信息：通过核查、监控、扫描信息系统，可以获得系统的网络空间的专属标识信息及内部的组织关系和信任关系的关联信息

结构属性-脆弱特征

- 脆弱特征是将系统从易受攻击状态与难受攻击状态区分开的一个特征，一般指操作系统或软件的漏洞、安全配置错误和合规性问题。
- 输出
 - 脆弱性分布图
 - 高危问题的主机集合；

交互属性

- 交互属性是信息系统在网络空间中活动时所表现的特性，是指在各种网络应用实践活动的基础上信息系统与网络空间各类组成部分之间发生的各种关系总和，是不能脱离网络空间而孤立生存的属性。交互属代表信息系统的关系性维度，用于表示实体之间的关系，
 - 访问控制特征
 - 依赖特征
 - 威胁特征

交互属性-访问控制特征

- 访问控制特征主要用于描述信息系统与其他网络空间的组件之间的各种数据交互行为，可以表征业务系统的运营情况及安全控制情况；
- 输出
 - 业务系统访问排名
 - 业务系统访问分布图
 - 业务系统的安全措施分析，即业务系统在整个访问线路上的安全防护措施有哪些？
 - 安全措施防护了哪些业务系统；
 - 识别防护措施的冗余、交叉的现象

交互属性-依赖特征

- 业务信息系统对IT基础设施的资源依赖性访问；
 - 基础网络服务
 - 各类服务器的CPU、内存、存储、网络等资源的基本使用情况，并统计各类业务系统对应用各类资源的占比。
 - DNS，业务服务器请求DNS的资源情况需要应该比较小（待解决），但是被请求的可行性比较大。
 - DNS，客户机访问DNS日志单独分析（应区分本单位服务器和外网服务器）
 - DHCP，客户机申请IP的情况，历史记录和跟踪。周期计算某时刻已使用IP/全部IP
 - NTP，关注可用性
 - 虚拟平台
 - 虚拟平台的CPU、内存、存储、网络等资源的基本使用情况，并统计各类业务系统使用虚拟平台各类资源的占比。
 - 网络设备
 - 业务流量分布分析
 - 流量异常检测

交互属性-威胁特征

- 资产面临各类威胁，威胁时可能导致对系统或组织的损害的不期望事件的潜在原因，威胁源可以分为三类：自然威胁，人为威胁和环境威胁。在安全数据分析中重点关注黑客攻击、计算机犯罪、系统入侵之类的人为威胁，包括恶意IP/域名，网络攻击行为等等。业务系统面临的各种威胁特征，主要是从信息安全设备获取的，例如入侵检测设备，APT检测、边界防护设备。

反应属性

- 反应属性：表现为系统的内在活动性，也即信息系统的内部活动的总和，包括信息系统各种业务服务、各类计算、通信、存储、网络等等资源的动态变化。反应属性代表变化性维度，用于识别实体内在状态的变化。
 - 内部关联特征
 - 业务可用特征
 - 系统可用特征。

反应属性-内部关联特征

- 内部交互特征主要用于描述业务信息系统内部不同组件之间的信息交互情况。业务系统内部组件通信，反映业务系统内部资产之间数据交互的必要性、流量变化情况。

反应属性-业务可用特征

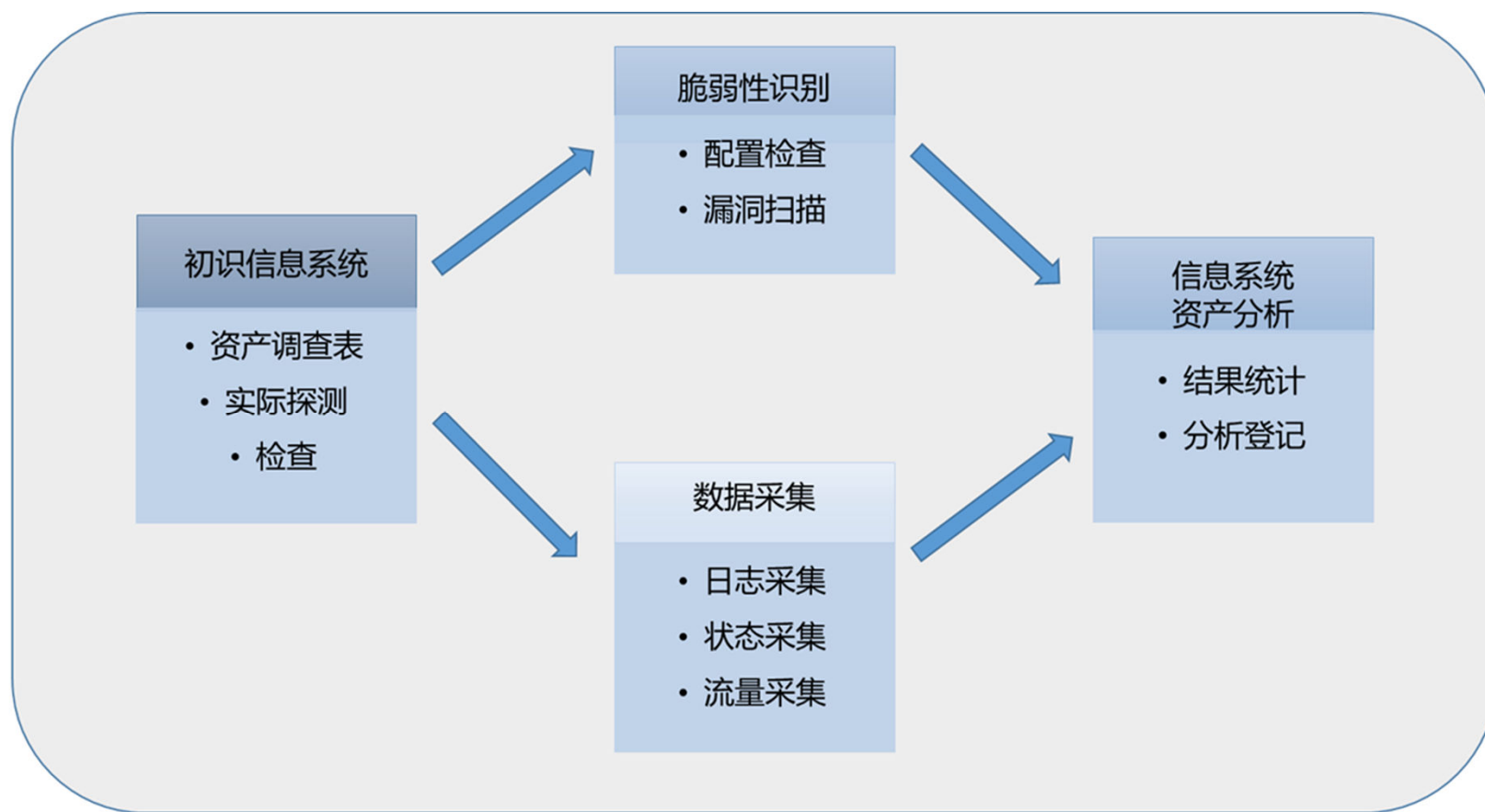
- 业务状态特征主要用于描述信息系统的业务应用占用的计算、内存、硬盘/存储、网络等资源的随机变化，以及年、月之间的使用量发生变化等，体现了业务的可用性。业务可用性要通过基于角色的业务视图，提供业务流和服务的可见性。需要从最终用户的角度来衡量业务影响和风险，建立和维护以业务为中心的SLA。

反应属性-系统可用特征

- 服务器可用特征主要用于描述业务信息系统的所依赖的主机的计算、内存、存储、网络、硬盘等资源的随机变化，以及年、月之间的使用量发生变化等。系统可用性体现在各类应用程序对服务器系统各种资源的内在竞争关系。

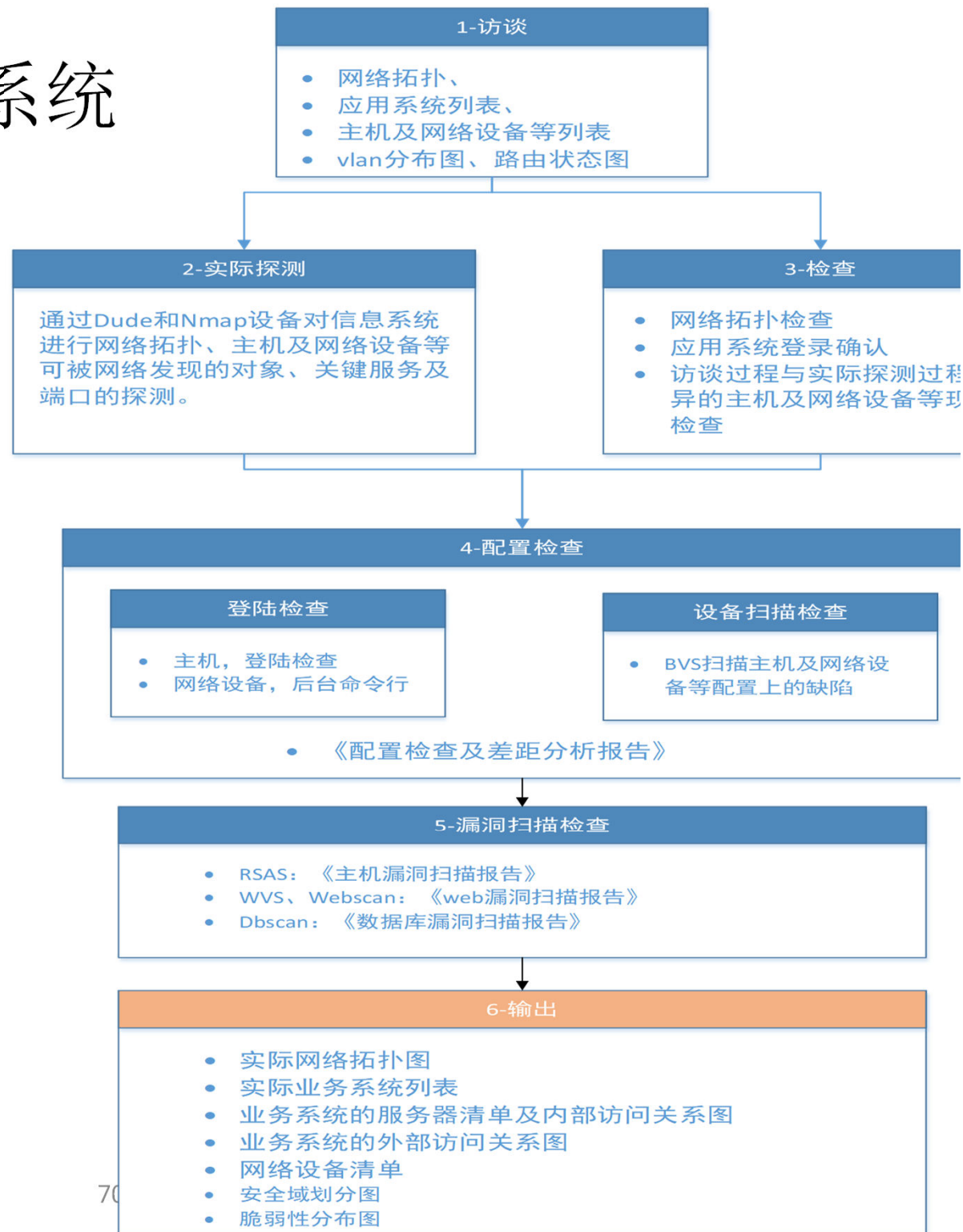
信息系统的属性识别过程

- 步骤一：初识信息系统（结构属性）
- 步骤二：可用性动态监控（依赖特征、反应属性）
- 流程三：日志监控（访问控制特征、威胁特征）



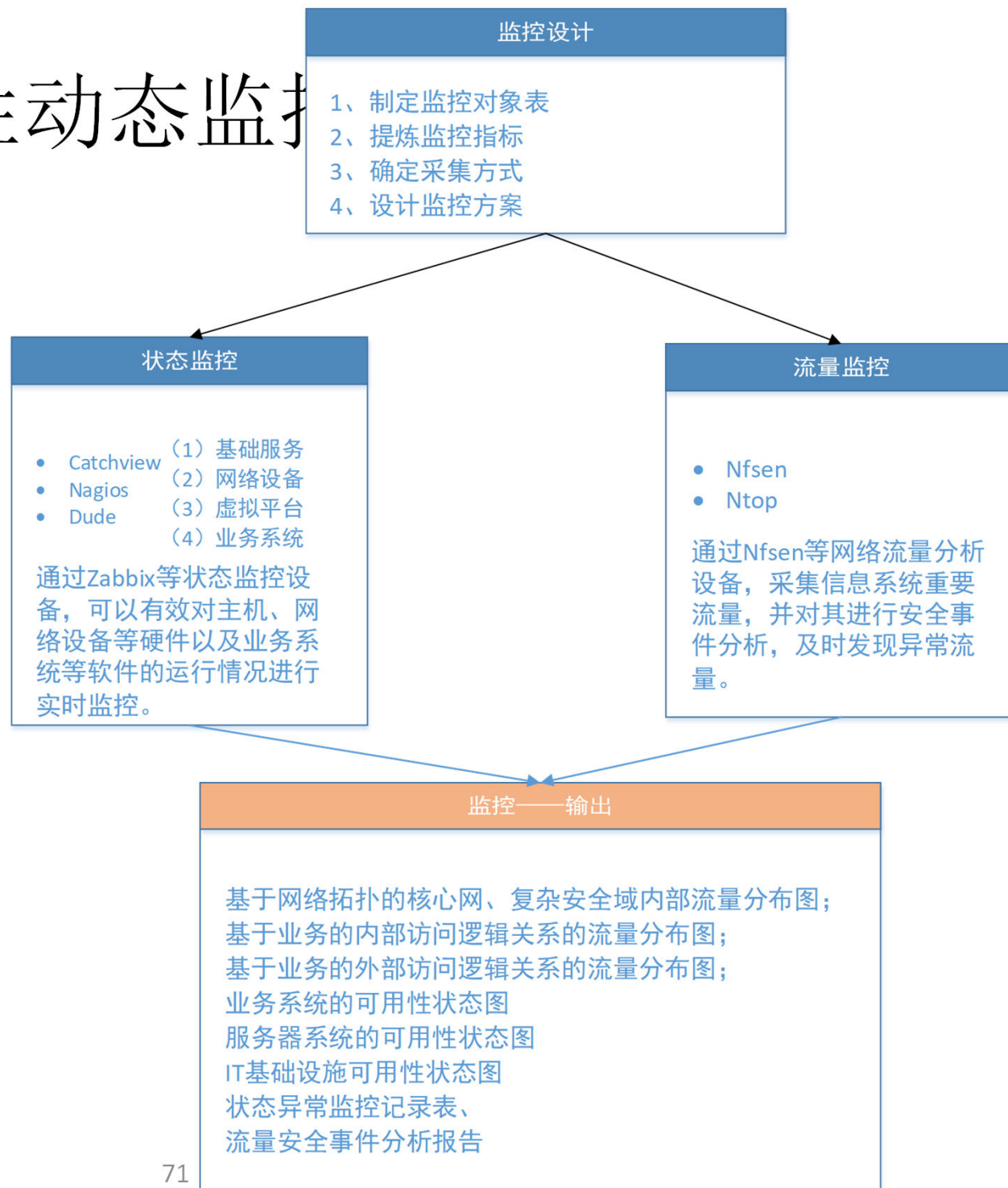
步骤一：初识信息系统

初识信息系统，主要通过预定的方法、工具、流程，对组织的IT基础设施和业务信息资产进行发现与核查，综合评估各类信息资产在组织业务和应用流程中的重要程度、逻辑依赖关系、自身的脆弱性等各类结构属性，为用户提供一系列的资产地图，提升了用户对信息系统的资产、系统运行依赖关系、网络连接状况的感知能力。（重点识别结构属性的3个特征）



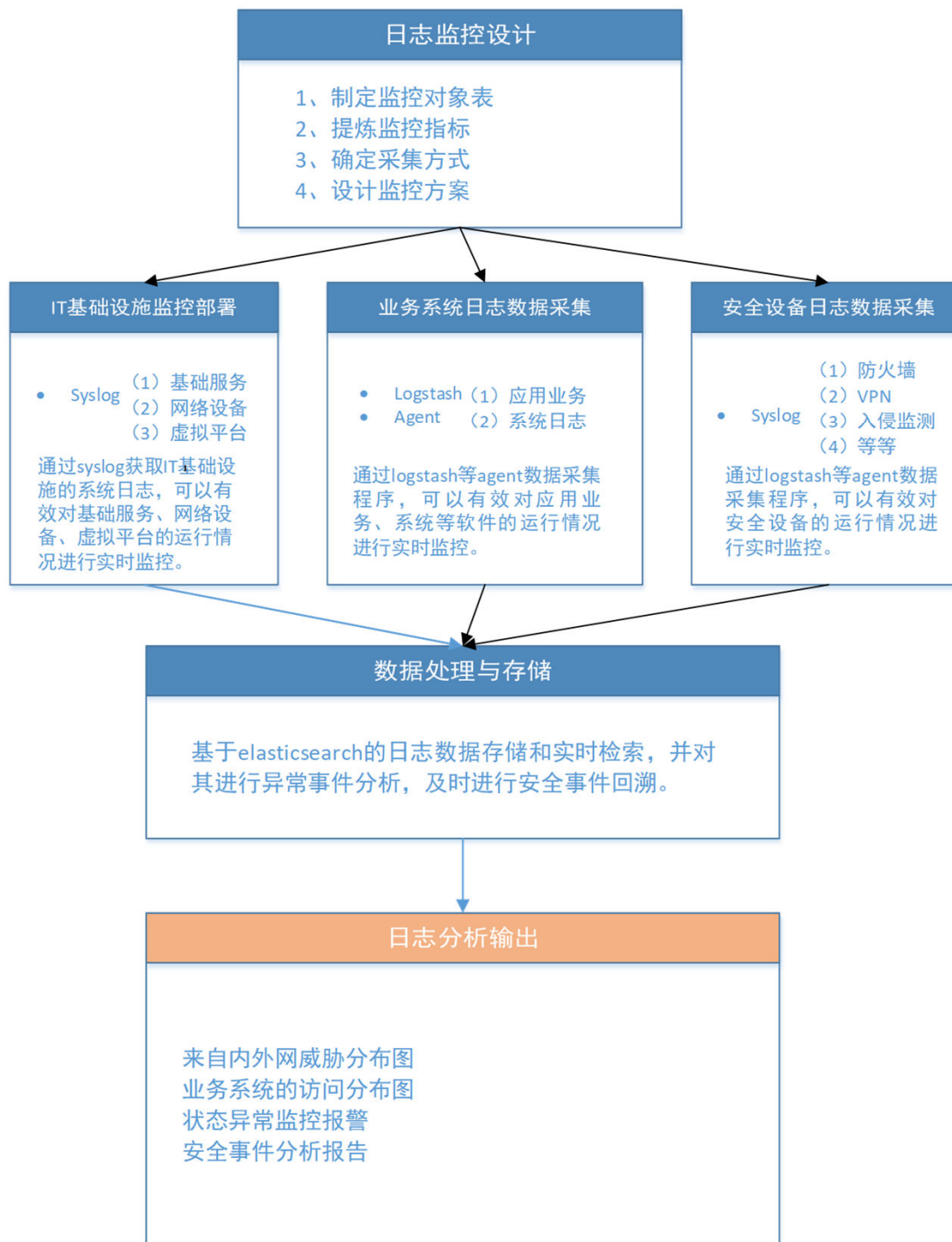
步骤二：可用性动态监控

- 可用性动态监控：通常采用分布式监控系统，支持多种采集方式和采集客户端（专用agent，snmp等），用来监控IT基础设施和业务应用系统的可用性和性能，以及网络站点的可用性、页面完整性及运行状态，实时发现各类信息资产动态特性，各种资源的竞争和依赖关系、业务系统内部的访问逻辑。
 - 依赖特征
 - 反应属性的3个特征



流程三：日志监控

- 采集各类信息系统的日志数据分析系列特征
 - 访问控制特征
 - 威胁特征



信息系统属性分析

- 基础设施的异常识别（IT基础设施的状态）
 - 基础服务
 - 网络
 - 大流量
 - 分布异常
 - 虚拟化
- 异常路径关联图（威胁路径图）
 - 识别边界
 - 识别信任关系
- 安全措施有效性的综合分析
- 业务系统关注度分析
 - 脆弱性、威胁、安全措施、业务访问度量

作业-资产发现和信息收集

- 目标：上海商学院、上海音乐学院、上海海洋大学、上海海事大学、上海电机学院、复旦大学管理学院（<https://www.fdsm.fudan.edu.cn>）
- 常用工具:spiderfoot、www.shodan.io, wappalyzer、**OneForAll**（一款强大的子域名收集工具）
 - 1、识别各学校或学院所有的域名信息及IP地址；
 - 2、所有接入互联网的web服务器及组件；
 - 3、尝试搜集所有暴露在公网（包括github）的相关信息。

小结

信息安全不是绝对的，是一个过程，只能在不断的实践中完善。